TECHNICAL DETAIL

Title	Stored Cross-Site Scripting (XSS) via Malicious HTML Injection in Knowledge Capturing Content
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com)
Date	2025-12-28
Affected Asset	https://bertani.my.id/admin/posts/edit
Severity	Medium
CVSS Score	5.4 CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:L/I:L/A:N.
Proof of Concepts	Please see Steps to Reproduce section

SUMMARY

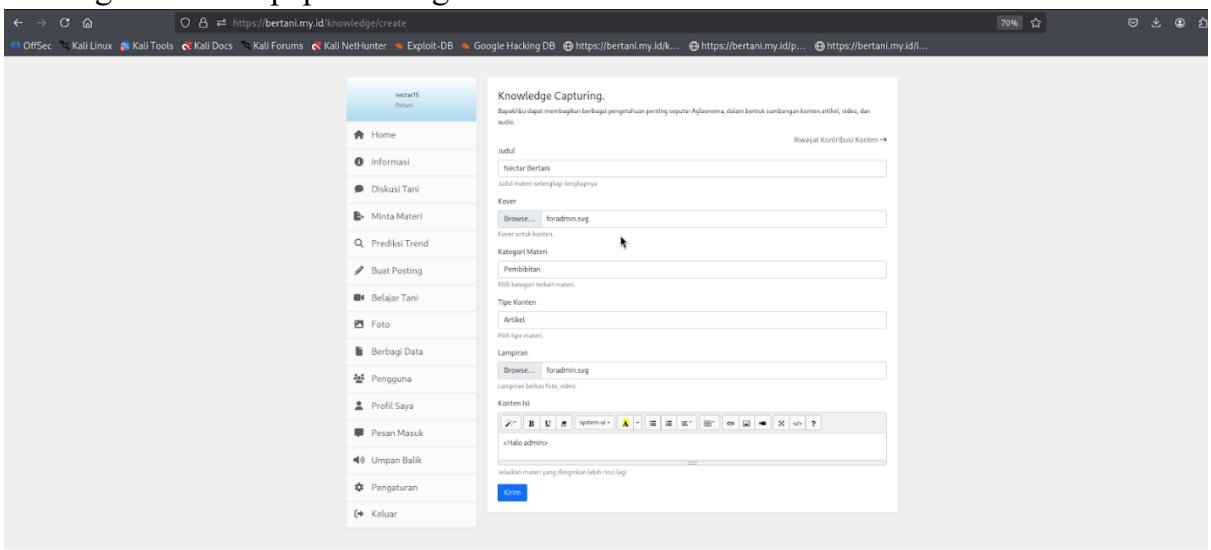
Laporan ini mengidentifikasi kerentanan Stored Cross-Site Scripting (XSS) pada fitur "Knowledge Capturing" di situs bertani.my.id. Kerentanan ini terjadi karena aplikasi tidak melakukan sanitasi yang memadai terhadap input pengguna di bagian "Konten Isi" sebelum menyimpannya ke database. Akibatnya, penyerang dapat menyuntikkan skrip berbahaya yang akan dieksekusi secara otomatis di sisi browser

STEPS TO REPRODUCE

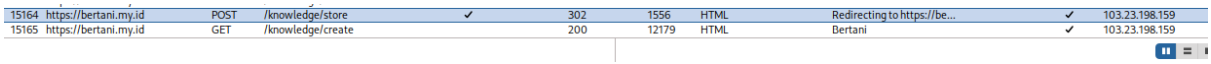
1. Login ke Akun Anda sebagai user di URL https://bertani.my.id/login

2. Nyalakan Proxy sesuaikan dengan port BurpSuit
3. Aktifkan fitur Intercept pada Burp Suite .

4. Masuk ke url bertani.my.id/knowledge/create dan pilih tipe konten artikel dan isi dengan tulisan apapun di bagian konten isi lalu kirim



5. Lalu masuk ke burpsuite dan kirim ke repeater yang post /knowledge/store



15164	https://bertani.my.id	POST	/knowledge/store	✓	302	1556	HTML	Redirecting to https://be...	✓	103.23.198.159
15165	https://bertani.my.id	GET	/knowledge/create		200	12179	HTML	Bertani	✓	103.23.198.159

6. Setelah itu pada bagian name=”content” ubah menjadi img src=x onerror="alert"('Nectar')">

Dashboard | Target | Proxy | Intruder | Repeater | Collaborator | Sequencer | Decoder

1 2 3 4 5 6 7 8 9 10 11 12 13

Send | Cancel | BurpAI

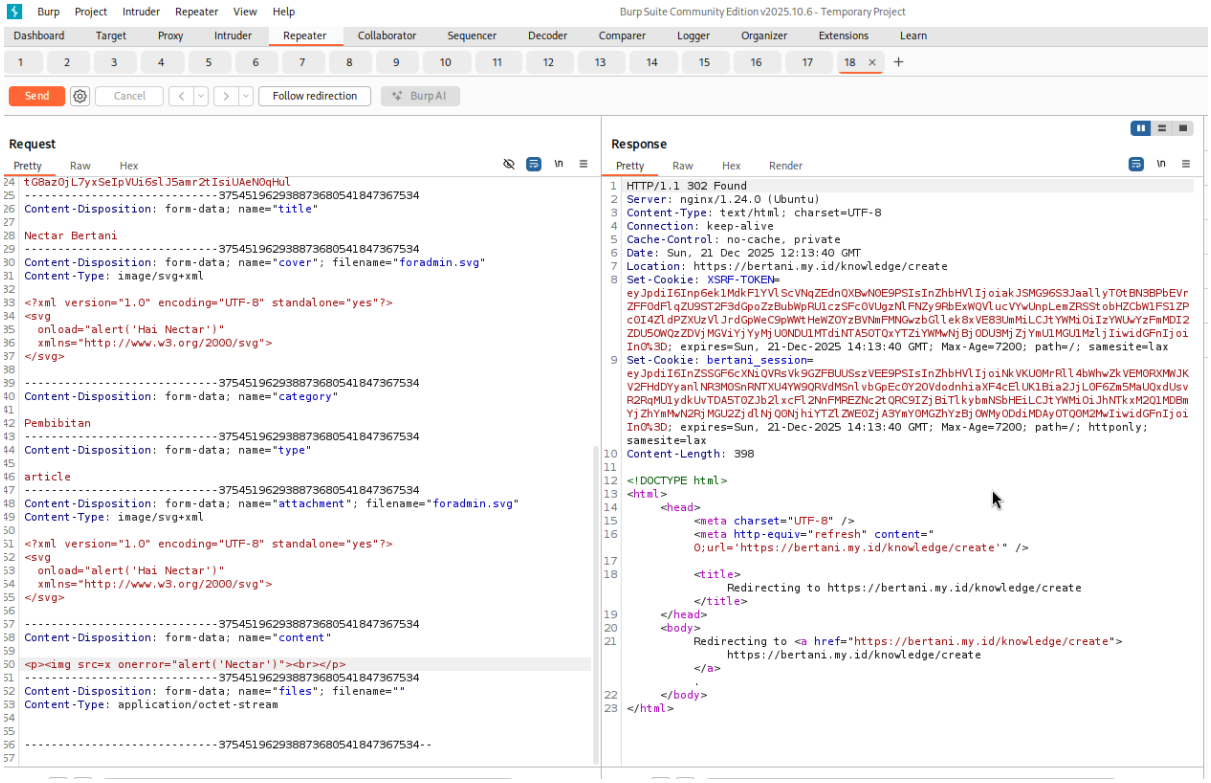
Request

Pretty | Raw | Hex

```
24 tG8az0jL7yxSeIpVUi6slJ5amr2tIsiUAeN0qHul
25 ----------------------------37545196293887368054184736753 4
26 Content-Disposition: form-data; name="title"
27
28 Nectar Bertani
29 ----------------------------37545196293887368054184736753 4
30 Content-Disposition: form-data; name="cover"; filename="foradmin.svg"
31 Content-Type: image/svg+xml
32
33 <?xml version="1.0" encoding="UTF-8" standalone="yes"?>
34 <svg
35   onload="alert('Hai Nectar')"
36   xmlns="http://www.w3.org/2000/svg">
37 </svg>
38
39 ----------------------------37545196293887368054184736753 4
40 Content-Disposition: form-data; name="category"
41
42 Pembibitan
43 ----------------------------37545196293887368054184736753 4
44 Content-Disposition: form-data; name="type"
45
46 article
47 ----------------------------37545196293887368054184736753 4
48 Content-Disposition: form-data; name="attachment"; filename="foradmin.svg"
49 Content-Type: image/svg+xml
50
51 <?xml version="1.0" encoding="UTF-8" standalone="yes"?>
52 <svg
53   onload="alert('Hai Nectar')"
54   xmlns="http://www.w3.org/2000/svg">
55 </svg>
56
57 ----------------------------37545196293887368054184736753 4
58 Content-Disposition: form-data; name="content"
59
60 <p>&lt;Halo admin&gt;<br></p>
61 ----------------------------37545196293887368054184736753 4
62 Content-Disposition: form-data; name="files"; filename=""
63 Content-Type: application/octet-stream
64
65
66 ----------------------------37545196293887368054184736753 4--
67
```

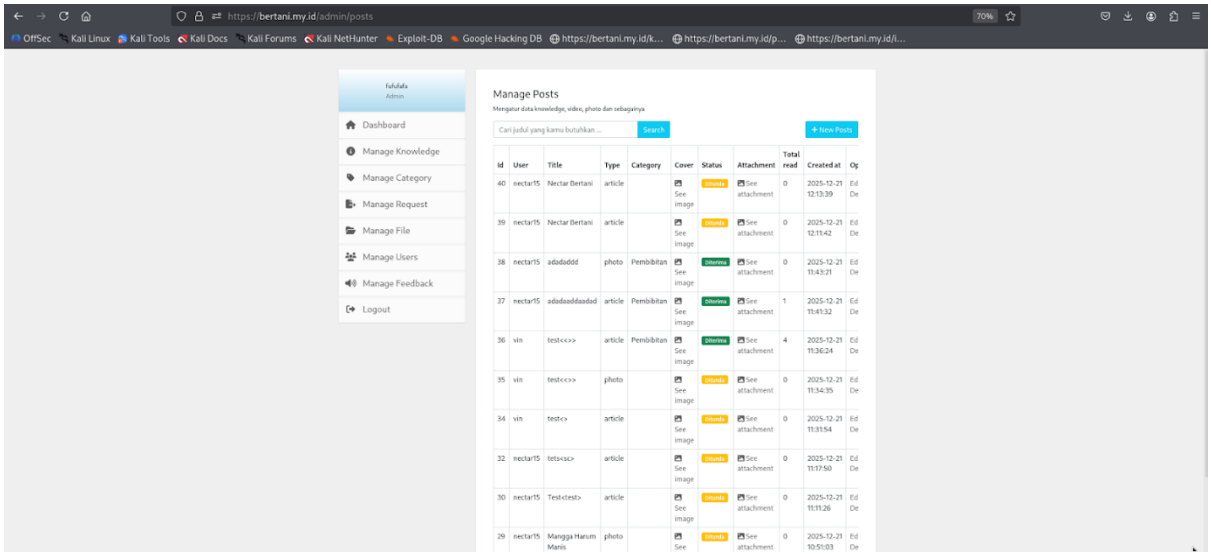
Search | 0 highlights

7. Seperti gambar dibawah

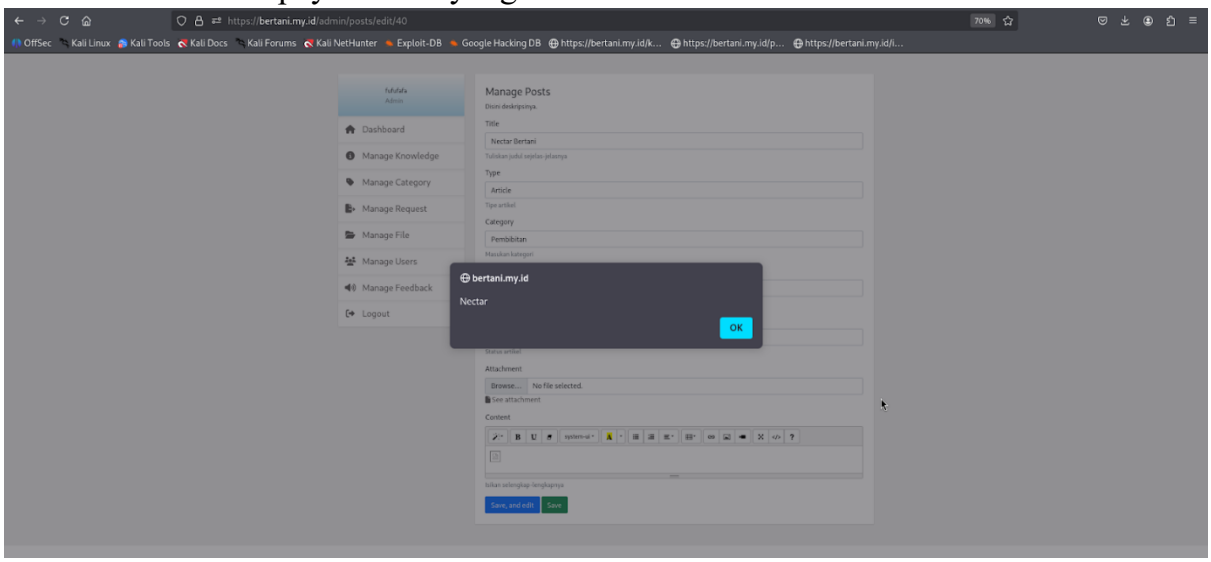


8. Login ke Akun Anda sebagai admin di URL https://bertani.my.id/login

9. Masuk ke url https://bertani.my.id/admin/posts lalu tekan aksi edit pada post yang kita upload tadi



10. Maka akan muncul payload xss yang kita masukan tadi



EXPECTED RESULT

Aplikasi seharusnya melakukan sanitasi atau *encoding* terhadap semua karakter khusus HTML dan skrip JavaScript yang dimasukkan ke dalam bidang "Konten Isi". Input tersebut harus ditampilkan sebagai teks statis atau HTML yang aman tanpa menjalankan perintah skrip apa pun di browser pengguna.

ACTUAL RESULT

Aplikasi menerima dan menyimpan input berupa tag HTML dan atribut JavaScript yang berbahaya (seperti onerror atau onload) secara langsung ke database. Saat pengguna dengan hak akses admin membuka halaman edit untuk konten tersebut di bertani.my.id/admin/posts/edit, skrip yang disuntikkan tersebut langsung dieksekusi oleh browser, yang dibuktikan dengan munculnya jendela *alert* bertuliskan "Nectar".

IMPACT

1. Phishing Sensitif: Penyerang dapat mengubah tampilan halaman admin khusus saat sedang diedit untuk menipu pengelola agar memasukkan informasi rahasia.
2. Admin Account Takeover: Penyerang dapat mencuri *session cookies* Administrator saat mereka melihat daftar lampiran di panel *Manage Posts*.

RECOMMENDATION

Untuk mengatasi masalah ini, disarankan langkah-langkah mitigasi sebagai berikut:

1. Input Sanitization: Gunakan pustaka pembersih HTML (seperti *HTML Purifier* untuk PHP/Laravel) untuk menyaring tag dan atribut berbahaya pada sisi server sebelum data disimpan ke database.
2. Output Encoding: Pastikan data yang ditampilkan kembali ke browser selalu melalui proses *encoding* (misalnya menggunakan fungsi {{ $variable }} pada Laravel Blade yang secara otomatis melakukan *escaping*).
3. Content Security Policy (CSP): Terapkan kebijakan CSP yang ketat untuk mencegah eksekusi skrip *inline* dan membatasi sumber pemuatan skrip eksternal.
4. Validasi Tipe File: Untuk unggahan SVG, lakukan pemeriksaan ketat untuk memastikan tidak ada skrip di dalam file XML tersebut.

REFERENCES

1. PortSwigger - Stored XSS: https://portswigger.net/web-security/cross-site-scripting/stored

2 .OWASP - Cross Site Scripting (XSS): https://owasp.org/www-community/attacks/xss/